



SOLUTION BRIEF

Building a Sovereign Cloud with Apache CloudStack



www.shapeblue.com



An open-source foundation for secure, compliant and vendor-independent cloud infrastructure

Are you planning or already building a sovereign cloud? How can you be sure you are choosing the right technology foundation - one that gives you genuine control over your data, infrastructure and operations?

This guide explores what true cloud sovereignty means, the requirements and regulations you need to consider, and how to evaluate your technology options. It also explains why open-source Apache CloudStack provides a strong foundation for building a secure, compliant and vendor-independent sovereign cloud.

Executive summary

Sovereignty has moved from a policy discussion to a procurement requirement. Organisations that hold sensitive or regulated data increasingly need to prove:

- where does the data live
- who can compel access to it
- who operates the platform and whether they can leave.

In Europe the pressure comes from regulation and public investment; in the United States it comes from federal mandates.

This brief is built around the questions that decision-makers ask: How to build a sovereign cloud?

It sets out the real motivations behind sovereign-cloud projects, the criteria used to evaluate them, the process organisations follow, and how the requirements differ between the European and US markets. It then explains where open-source Apache CloudStack fits as a strategic choice and shows a real public-sector example.

What Real Sovereignty Means

“Sovereign” is often reduced to “data stays in-country”. Real sovereignty is a property of how the whole system is owned, operated and governed. It rests on three dimensions that must all hold:

Dimension	What it means
Data sovereignty	Data is stored, processed and remains subject only to the laws of the chosen jurisdiction, with no path for foreign access.
Operational sovereignty	Local teams (yours or a trusted partner's) run and support the platform, with no mandatory dependency on a foreign vendor's operations staff.
Technical / software sovereignty	The software itself is open, auditable and forkable, so you are never captive to a single vendor's roadmap, licence terms or pricing.

A solutions that matches only one of these dimensions is not sovereign. The value of open source here is not the licence cost; it is that ownership, audit and exit become real rather than contractual.

What drives a sovereign-cloud project?

Sovereign-cloud projects are driven by a consistent set of fears and motivations:

- **Fears:** losing control of highly sensitive data; a foreign legal reach such as the US CLOUD Act compelling disclosure; over-dependence on a small number of vendors (commonly Microsoft and VMware); and lock-in to a public cloud that is hard and costly to leave.
- **Motivations:** to stay in control of their own data; to modernise infrastructure without moving to public cloud; to use open source as the basis of independence; and to hold credible, risk-based exit strategies for the components that matter most.

These fears are not abstract. They come straight from organisations building sovereign clouds today, including the European public-sector example later in this brief.

How organisations evaluate a sovereign cloud

Sovereignty is assessed layer by layer, not as a single checkbox. Buyers building sovereign clouds tend to apply the same criteria:

- **Jurisdiction of every layer:** not just the cloud platform, but the management-server operating system, the database and the parties that support them must sit within the chosen jurisdiction. Ruling out a foreign-headquartered platform while keeping a foreign-supported OS or database does not close the gap.
- **Who provides support:** the entity that patches and supports each component, and holds operational knowledge of it, matters as much as where the code was written. Sovereign buyers increasingly require support from within their own jurisdiction.
- **Control and independence:** the control plane runs on infrastructure the organisation owns, or that a trusted local partner operates, with no foreign operator holding privileged access.
- **Openness and exit:** open source, open standards and a documented exit path, so no proprietary control plane can trap data or operations.
- **Regulatory fit:** alignment with the frameworks that apply in the organisation's market, which differ between Europe and the United States (covered below).

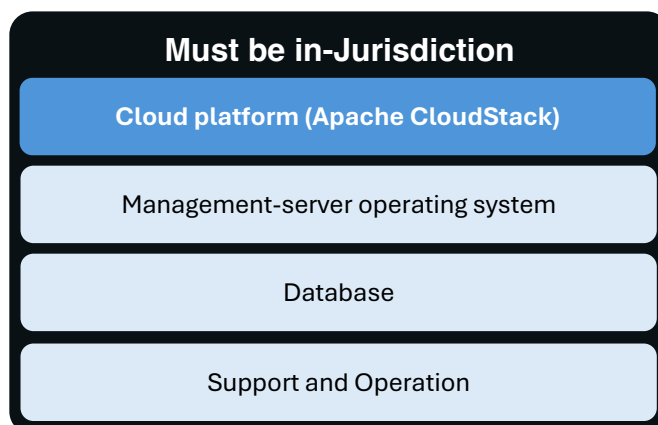


Figure 3. Sovereignty holds only if every layer, and its support, sits in your jurisdiction.

Your path from evaluation to production

When you set out to build a sovereign cloud, the work falls into four phases. ShapeBlue recommends moving through them in order, so you always know where you are and what to do next:

- **Assess:** map your data residency, jurisdiction and lock-in exposure, and identify which layers are not yet sovereign, including the OS, database and support relationships, not just the platform.
- **Design:** choose your in-jurisdiction components, set your assurance and certification targets, and lay out your reference architecture and operating model.
- **Migrate:** move your workloads onto the sovereign platform in stages. If you are leaving proprietary virtualisation, this includes VMware-to-KVM migration, with rollback points at each step.
- **Operate:** run the platform with your local teams or a trusted in-jurisdiction partner, keep it patched and compliant, and rehearse your exit path so it stays credible.



Figure 4. The four phases of a sovereign-cloud project.

Sovereign Cloud Requirements Across Europe and the United States

If you are considering a sovereign cloud, you are likely asking four fundamental questions:

- Where will your data reside?
- Who could legally compel access to it?
- Who will operate and control the platform?
- And can you move away from the technology if your requirements change?

These questions apply in every market, but the concerns behind them differ. In Europe, you may be focused on reducing exposure to US-headquartered technology providers and foreign jurisdiction. In the United States, the priority is more likely to be meeting the requirements of federal programmes and regulated sectors. These different drivers will shape which technology and deployment options are acceptable to your organisation. The table below compares the key considerations.

Aspect	Europe	United States
Primary concern	Exposure to non-EU providers under laws such as the US CLOUD Act; keeping data under EU jurisdiction.	Meeting federal mandates and handling controlled data, rather than avoiding domestic vendors.
Key frameworks	GDPR, NIS2, DORA, EU Cloud Sovereignty Framework (SEAL), national schemes (SecNumCloud, C5, ENS).	FISMA, FedRAMP, NIST SP 800-53 / 800-171.
Management-server OS (examples)	An EU-based or EU-supported Linux, e.g. openSUSE (SUSE, Germany), AlmaLinux or Rocky Linux with EU support.	RHEL or another enterprise Linux with US-based support is generally acceptable.
Database (examples)	An EU-supported option, e.g. Percona or MariaDB with EU support.	A commercial or open-source database with US support is generally acceptable.
Support & operations	Must sit within the EU or the chosen member state.	US-based support is generally acceptable.

The vendors named above are examples that illustrate the jurisdiction-of-each-layer criterion, not endorsements. What matters is that each layer's software and its support meet the jurisdiction the organisation is accountable to.

The European picture. For most European organisations the trigger is legal exposure. A data centre inside the EU is not enough if the provider that runs it can be compelled under foreign law, so the shortlist narrows to platforms and suppliers that sit under EU jurisdiction, with EU-based support and, increasingly, alignment to the EU Cloud Sovereignty Framework. Public-sector bodies feel this most sharply, because they hold citizens' data and answer to national regulators.

The United States picture. In the US the concern is rarely a domestic vendor. Sovereignty there is about meeting federal obligations such as FedRAMP authorisation and FISMA controls for government systems and controlled unclassified information. The same open, self-hosted, validated and auditable platform serves both markets; what changes is which boxes the auditor is checking.

Sovereign options among CloudStack integrations

The same pattern shows up in the technologies that integrate with CloudStack. Across the layers most relevant to sovereignty, most proprietary options are US-based, while European and community-governed options exist for each. The table lists examples from the CloudStack integration ecosystem, by the jurisdiction of the vendor or steward:

Layer	European Union	United States	Community / open source
Hypervisor	Proxmox VE (AT), XCP-ng (FR)	VMware vSphere, Citrix Hypervisor, Firecracker	KVM
Storage	StorPool (BG), LINBIT/DRBD (AT)	Dell PowerFlex, Pure Storage, Cloudian, MinIO	Ceph
Backup & DR	BackRoll (FR)	Dell NetWorker, Veeam	CloudStack native (NAS)

Examples, not endorsements. Community-governed projects such as KVM and Ceph have no single national owner; sovereignty comes from operating and supporting them within your jurisdiction. For proprietary products, what matters is the parent company's jurisdiction, which is what drives exposure such as the CLOUD Act.

The regulatory landscape

Sovereignty requirements come from law and certification schemes, not from marketing. This section summarises the instruments that matter on each side of the Atlantic and what each one asks of a cloud.

Europe: GDPR, NIS2 and DORA

GDPR² governs how the personal data of people in the EU is processed and transferred. Combined with the US CLOUD Act¹ it creates a conflict of laws: a US-headquartered provider can be compelled under US law to do something GDPR forbids, wherever the data is stored. The “Schrems II” judgment¹² invalidated the previous EU-US transfer framework on this point, and the current Data Privacy Framework¹¹ faces similar challenges. NIS2³ raises cybersecurity and supply-chain obligations for essential and important entities, with a compliance deadline in October 2026, and DORA⁴ has applied to EU financial entities since January 2025, adding strict rules on ICT risk, third-party oversight and exit strategies. All three assume you can demonstrate control of your platform, your suppliers and a credible way out.

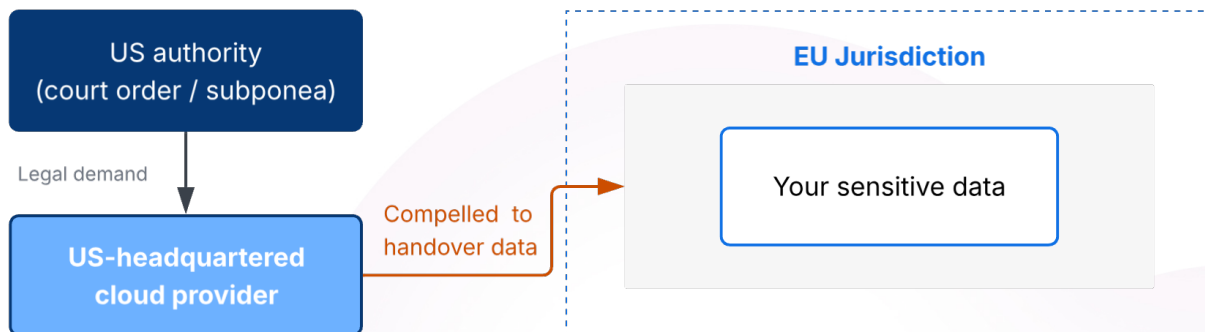


Figure 1. Jurisdiction follows the provider's parent company, not where the data is stored.

Europe: the EU Cloud Sovereignty Framework (SEAL)

In 2026 the European Commission set out how it evaluates sovereign cloud in its Cloud Sovereignty Framework, the benchmark it used to award a €180M sovereign-cloud tender⁶ and now recommends for public and private organisations⁷. Providers are scored against 48 criteria in eight categories, including legal and jurisdictional, operational, supply chain and technological, and each is assigned a Sovereignty Effectiveness Assurance Level (SEAL) from data sovereignty up to full sovereignty. An owned, open-source cloud maps well to the higher levels, because the legal, operational and supply-chain criteria are met by design rather than by a foreign vendor's promise. The market backs this up: Gartner projects European sovereign-cloud IaaS spending will grow from roughly \$6.9B in 2025 to \$12.6B in 2026 and \$23.1B by 2027⁵.

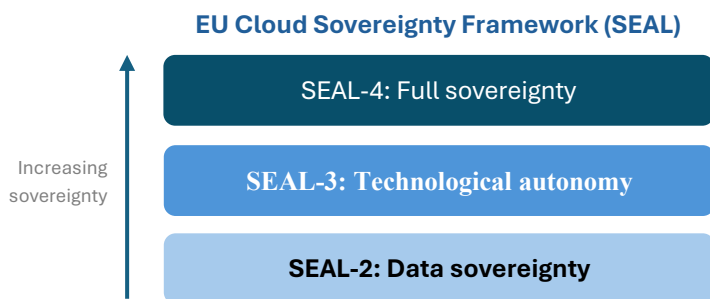


Figure 2. The SEAL levels of the EU Cloud Sovereignty Framework.

The United States: FISMA and FedRAMP

In the United States, sovereignty is framed by federal programmes such as FISMA and FedRAMP and by the NIST SP 800 series. For government systems and controlled unclassified information, US rules require validated cryptography (FIPS 140), for which a compliant CloudStack distribution is available⁹. The driver differs from Europe, but the platform requirements converge on the same shortlist: open, self-hosted, validated and auditable.

A quick-reference map

The table below maps the boundary each instrument cares about to the control a CloudStack-based cloud gives you over it:

Driver / Regulation	The boundary it cares about, and how CloudStack gives you control of it
Data residency (GDPR)	Where personal data lives and who can reach it. Keep it within the chosen jurisdiction, on infrastructure you or a local partner control end to end.
Extraterritorial reach (CLOUD Act)	Whose law follows the data. A locally owned and operated cloud removes the foreign-parent exposure that in-region hosting alone does not.
Resilience & exit (NIS2, DORA)	Whether you can operate, oversee suppliers and leave. Full control of the management plane, audit logging and a credible exit path.
Sovereignty rating (EU CSF / SEAL)	How independent the whole stack is. Open source and an owned control plane answer the legal, operational and supply-chain criteria by design.

CloudStack does not, by itself, make an organisation compliant. That depends on how the platform is deployed and governed. What it gives you is ownership of the isolation boundary, the audit surface and the exit path that these frameworks assume you control.

Why to Build a Sovereign Cloud with Apache CloudStack

Apache CloudStack is a mature, open-source IaaS platform that has run production public and private clouds for well over a decade. For a sovereign-cloud strategy, its relevance is strategic rather than a feature list:

- **Open source under neutral governance.** A top-level Apache Software Foundation project under the permissive Apache 2.0 licence. Governance sits with a vendor-neutral foundation, not a single commercial owner, so the source can be audited and forked. This is the basis of technical and software sovereignty.
- **You own the control plane.** The entire management plane runs on infrastructure you control, with no mandatory telemetry or foreign operator with privileged access. This is what makes operational sovereignty real.
- **You choose the sovereign components.** Because it is open source and runs on standard Linux with KVM, you select the management-server OS, database and support partner that meet your jurisdiction, instead of accepting a fixed, vendor-controlled stack. VMware and XCP-ng/XenServer are also supported, and other hypervisors through the CloudStack Extensions Framework.
- **Proven and supported for the long term.** The 4.22 LTS line (November 2025) carries 24 months of support[®], scales to tens of thousands of *Hosts*, and is deployed in thousands of organisations worldwide.

A Reference Architecture

A typical sovereign CloudStack cloud places every layer inside a single sovereign boundary, from the interfaces users touch down to the facilities that host it:

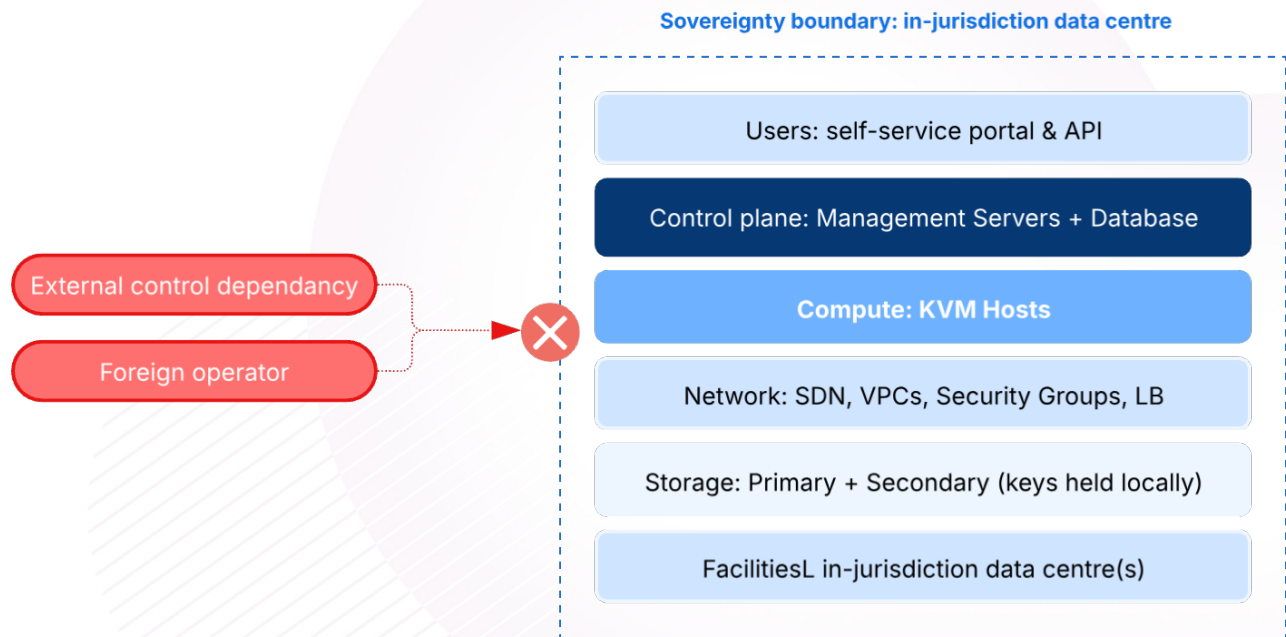


Figure 5. Reference architecture: every layer sits inside the sovereign boundary.

In more detail, each layer is open and self-hosted so that none introduces a foreign dependency:

- **Compute:** commodity *Hosts* running the KVM hypervisor for a fully open virtualisation layer.
- **Network:** software-defined *Networks*, *VPCs*, *Security Groups* and *Load Balancing*, all managed within the platform.
- **Storage:** local *Primary Storage* and *Secondary Storage* (Ceph, NFS or block), with encryption keys held locally.
- **Control plane:** the CloudStack *Management Servers*, database and API, running on in-region infrastructure with no external control dependency.
- **Security & governance:** local identity integration, full audit logging, and *Region/Zone* isolation to enforce residency.

Because every layer above the facilities is open and self-hosted, the organisation can show exactly where data lives, who can access it and how to exit. Those are the questions auditors and regulators actually ask.

In practice: Statistics Netherlands

Statistics Netherlands (CBS) is the Dutch national statistics office, with around 2,000 staff and roughly 5,500 published statistics. Its raw material is “micro data”: highly sensitive information about individuals and companies, from health and income to taxes and education. As Erik Logtenberg explained in a public talk at the CloudStack European User Group¹¹, that combination drives the sovereignty requirement: the organisation has to keep tight control of very sensitive data while also publishing openly, so it cannot simply build a wall around everything.



Figure 6. The CBS sovereignty journey and its risk-based exit strategies.

The tension is concrete. CBS holds data on people's health, income, taxes and education, and even survey answers such as whether people feel safe walking the streets at night, alongside competition-sensitive company data. Its whole purpose, though, is to publish. It cannot simply wall everything off, so it has to run very high security on one side and openly published statistics on the other, from the same infrastructure. That is what makes control of the platform non-negotiable, and it is the fear of losing that control that starts the sovereignty conversation.

Like many government bodies, CBS ran a traditional, managed-infrastructure data centre, where an application team asked the infrastructure department for a server rather than serving itself. The common answer to modernising that model, and the one CBS explicitly rejected, is to move to public cloud. Instead of letting its data centre age into legacy, it chose to reinvent its own infrastructure and run a modern private cloud on Apache CloudStack, keeping full control and sovereignty precisely because the platform is open source. The work is honest about its stage: a working pilot, with Kubernetes already in production and the private cloud not yet fully live.

The approach is risk-based. CBS identified its biggest dependencies, Microsoft and VMware, and built specific exit strategies for them: replacing VMware with a CloudStack private cloud with self-service for DevOps teams, and piloting Nextcloud to move document collaboration off SharePoint. Sovereignty, in other words, is treated as a layered, ongoing posture, not a one-off deployment. It is a real European public-sector example of the fears, motivations and criteria described earlier in this brief.

Common pitfalls to avoid

A few recurring mistakes turn a sovereign-cloud project into a false sense of security:

- **In-region is not the same as sovereign.** Hosting inside your country does not remove foreign legal reach if the provider that operates it sits under another jurisdiction.
- **Sovereign-washing.** A support contract for open-source software is not sovereignty. Look at how the whole system is owned, operated and governed.
- **Forgetting the layers beneath the platform.** The operating system, database and their support carry the same jurisdiction question as the cloud platform itself.
- **Treating it as a one-off.** Sovereignty is an operating posture. Without maintenance, patching and a rehearsed exit path, it decays.

Questions to ask before you commit

Whether you are pressure-testing your own plans or a supplier's offer, these questions cut to what matters:

- Under which country's laws do every layer of this cloud, and its support, ultimately fall?
- Who can be compelled to hand over data, and by whom?
- Can we operate the platform with no mandatory foreign involvement?
- Is the source open, and can we exit without a proprietary control plane in the way?
- Which frameworks apply to us, and can we evidence them to an auditor today?
- What is the exit strategy for our biggest dependencies, and has it been tested?

Sovereignty Readiness Checklist

A short self-assessment. The more items you cannot tick, the wider the sovereignty gap.

Data

- ☐ You know exactly which jurisdiction(s) your data is stored and processed in.
- ☐ No foreign law can compel access to that data.
- ☐ You, not your provider, hold the encryption keys.

Operations

- ☐ The management plane is operated by you or a trusted in-jurisdiction partner.
- ☐ The platform can run with no mandatory dependency on a foreign vendor's staff.
- ☐ No telemetry or control traffic leaves your sovereign boundary.

Software, support and exit

- ☐ The platform's source code is open and auditable.
- ☐ The management-server OS, database and their support all sit within your jurisdiction.
- ☐ You have a documented, contractual exit path with no proprietary control plane in the way.

Compliance

- ☐ You can evidence data residency to an auditor today.
- ☐ You are covered for the frameworks that apply in your market (EU: NIS2, DORA, EU CSF; US: FISMA, FedRAMP).

“Apache”, “CloudStack”, “Apache CloudStack”, the Apache CloudStack logo, the Apache CloudStack Cloud Monkey logo and the Apache feather logos are registered trademarks or trademarks of The Apache Software Foundation.

Glossary

CLOUD Act: US law (2018) allowing US authorities to compel US-headquartered providers to produce data they control, regardless of where it is stored.

DORA: Digital Operational Resilience Act, Regulation (EU) 2022/2554, applicable to EU financial entities since January 2025.

EU CSF / SEAL: The EU Cloud Sovereignty Framework and its Sovereignty Effectiveness Assurance Level rating.

FedRAMP / FISMA: US federal programmes governing the security authorisation and management of information systems and cloud services.

NIS2: Directive (EU) 2022/2555 raising cybersecurity obligations across the Union, with an October 2026 compliance deadline.

Sovereign cloud: Cloud infrastructure whose data, operations and software remain under the control of, and subject to the laws of, a chosen jurisdiction.

Sources & references

Regulatory and market claims are drawn from primary and authoritative sources. Figures were current as of July 2026; re-verify before republication.

1. US CLOUD Act, H.R. 4943, 115th Congress (2018). <https://www.congress.gov/bill/115th-congress/house-bill/4943/text>
2. GDPR, Regulation (EU) 2016/679, EUR-Lex. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
3. NIS2, Directive (EU) 2022/2555, EUR-Lex. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
4. DORA, Regulation (EU) 2022/2554, EUR-Lex. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng>
5. Gartner, “Worldwide Sovereign Cloud IaaS Spending Will Total \$80 Billion in 2026” (9 Feb 2026). Europe: \$6.9B (2025) to \$12.6B (2026) to \$23.1B (2027). <https://www.gartner.com/en/newsroom/press-releases/2026-02-09-gartner-says-worldwide-sovereign-cloud-iaas-spending-will-total-us-dollars-80-billion-in-2026>
6. European Commission, “Commission advances cloud sovereignty through strategic procurement” (17 Apr 2026). https://commission.europa.eu/news-and-media/news/commission-advances-cloud-sovereignty-through-strategic-procurement-2026-04-17_en
7. European Commission, “Sovereign Cloud Framework explained” (1 Jun 2026). https://commission.europa.eu/news-and-media/news/sovereign-cloud-framework-explained-2026-06-01_en
8. Apache CloudStack 4.22.0.0 LTS release (11 Nov 2025), Apache Software Foundation. <https://cloudstack.apache.org/blog/cloudstack-4.22.0.0-release/>
9. ShapeBlue, “Apache CloudStack FIPS Compliance” (2026). <https://www.shapeblue.com/cloudstack-fips-compliance/>
10. Erik Logtenberg (CBS), “CBS Digital Sovereignty Strategy,” talk at the CloudStack European User Group, The Hague (2026). <https://www.youtube.com/watch?v=q01zpInsqMY>

Further primary sources

11. EU-US Data Privacy Framework, Commission Adequacy Decision (EU) 2023/1795, EUR-Lex. https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj
12. “Schrems II”, CJEU judgment, Case C-311/18, 16 Jul 2020. <https://curia.europa.eu/juris/liste.jsf?num=C-311/18>
13. EUCS, European Cybersecurity Certification Scheme for Cloud Services, ENISA. <https://www.enisa.europa.eu/publications/eucs-cloud-services-scheme>
14. National assurance schemes: SecNumCloud (ANSSI, France), C5 (BSI, Germany), ENS (Spain).



ShapeBlue is the largest independent integrator of **CloudStack technologies globally**. We combine 100s of man-years of experience in designing and building complex cloud, network and storage infrastructure with globally leading skills in Apache CloudStack.

Apache CloudStack is **Used by** **Leading Cloud Providers** & Global Enterprises



© ShapeBlue Ltd. All rights reserved. ShapeBlue and the ShapeBlue logo are trademarks of ShapeBlue Ltd. All other trademarks, service marks, and logos referenced in this document are the property of their respective owners.

"Apache", "CloudStack", "Apache CloudStack", the Apache CloudStack logo, the **Apache CloudStack Monkey logo** and the **Apache feather logos** are registered trademark or trademarks of The Apache Software Foundation.